

Additional Security Findings

HostelGrievance application | Findings distinct from the two supplied lists

Finding ID	Severity	Finding	Primary location
ADD-SEC-01	HIGH	Plaintext Session Tokens Stored in the Database	src/server/auth/session.ts:17-20; src/server/db/schema.ts:14-18
ADD-SEC-02	MEDIUM	Unbounded Text Fields Permit Storage and Processing Exhaustion	src/server/routes/grievances.ts:79-116, 131-157, 216-231
ADD-SEC-03	MEDIUM	Oversized Uploads Are Fully Buffered Before Size Rejection	src/server/storage/attachments.ts:44-51
ADD-SEC-04	MEDIUM	Missing Baseline Browser Security Headers	src/server/app.ts:14-35
ADD-SEC-05	MEDIUM	Filesystem and Database Writes Are Not Atomic	src/server/routes/grievances.ts:97-116, 176-186
ADD-SEC-06	LOW	No Audit Trail for Privileged Grievance Changes	src/server/routes/grievances.ts:231-300; src/server/db/schema.ts:

Scope note: This report intentionally excludes the findings shown in the supplied images, including authorization gaps, unsafe filenames, session expiry/logout handling, permissive CORS, upload validation, detailed errors, localStorage auth state, password hashing, cookie flags, login rate limiting, ID collisions, CSRF, and seeded credentials.

ADD-SEC-01: Plaintext Session Tokens Stored in the Database

Severity: **HIGH** Primary location: src/server/auth/session.ts:17-20; src/server/db/schema.ts:14-18

Evidence and impact

createSession inserts the bearer token directly into the sessions table. Anyone who obtains a database copy, backup, or read access can use those tokens as authenticated sessions until they expire.

Recommended remediation

Hash session tokens before storage using a keyed digest or SHA-256 with a server-side pepper. Compare a hash of the presented token, rotate tokens after authentication-sensitive events, and protect database backups.

ADD-SEC-02: Unbounded Text Fields Permit Storage and Processing Exhaustion

Severity: **MEDIUM** Primary location: src/server/routes/grievances.ts:79-116, 131-157, 216-231

Evidence and impact

Title, description, and comment text are checked only for minimum length. Requests can submit arbitrarily large strings, causing memory use, database growth, slow responses, and excessive UI rendering.

Recommended remediation

Set explicit maximum lengths for every text field at the API boundary, reject oversized JSON bodies before parsing where possible, and enforce corresponding database and UI limits.

ADD-SEC-03: Oversized Uploads Are Fully Buffered Before Size Rejection

Severity: **MEDIUM** Primary location: src/server/storage/attachments.ts:44-51

Evidence and impact

bufferFromUpload calls file.arrayBuffer() before assertPermittedAttachment checks the byte count. An attacker can send many oversized uploads and force the process to allocate each request body before rejecting it.

Recommended remediation

Enforce Content-Length and multipart limits at the server/parser layer, stream uploads with a hard byte cap, and abort once the cap is exceeded. Keep the post-read check as defense in depth.

ADD-SEC-04: Missing Baseline Browser Security Headers

Severity: **MEDIUM** Primary location: src/server/app.ts:14-35

Evidence and impact

The application configures routing and CORS but does not set headers such as Content-Security-Policy, X-Content-Type-Options, Referrer-Policy, or frame protections. This increases the impact of future injection and clickjacking bugs.

Recommended remediation

Add a security-header middleware with a restrictive CSP appropriate for the app, X-Content-Type-Options: nosniff, Referrer-Policy, and frame-ancestors or X-Frame-Options. Add HSTS when served exclusively over HTTPS.

ADD-SEC-05: Filesystem and Database Writes Are Not Atomic

Severity: **MEDIUM** Primary location: src/server/routes/grievances.ts:97-116, 176-186

Evidence and impact

A grievance or attachment file is written separately from its database insert. A crash or database error between operations leaves orphaned files or metadata pointing to a missing file, enabling disk exhaustion and inconsistent records.

Recommended remediation

Use a transaction for related database changes, write to a temporary file and rename after validation, and remove the file when the database operation fails. Add startup reconciliation for orphaned files.

ADD-SEC-06: No Audit Trail for Privileged Grievance Changes

Severity: **LOW** Primary location: src/server/routes/grievances.ts:231-300; src/server/db/schema.ts:20-31

Evidence and impact

Warden status changes and student edits update the grievance but create no actor, previous-value, or timestamped audit record. Unauthorized or abusive changes may therefore be difficult to detect, investigate, or attribute.

Recommended remediation

Add an append-only audit table recording actor ID, role, action, target ID, old value, new value, timestamp, and request correlation ID. Restrict audit access and retain records according to policy.